

# FILE UPLOAD VULNERABILITY

إعداد الطالب: وليد عمرو عبد المعبود خيال

Group number :16

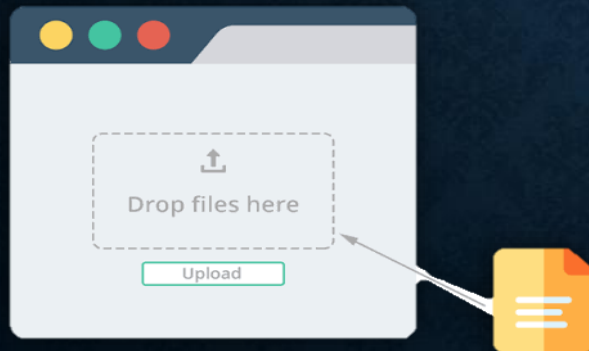
المادة : الأمن السيبراني NTI

## المحتويات

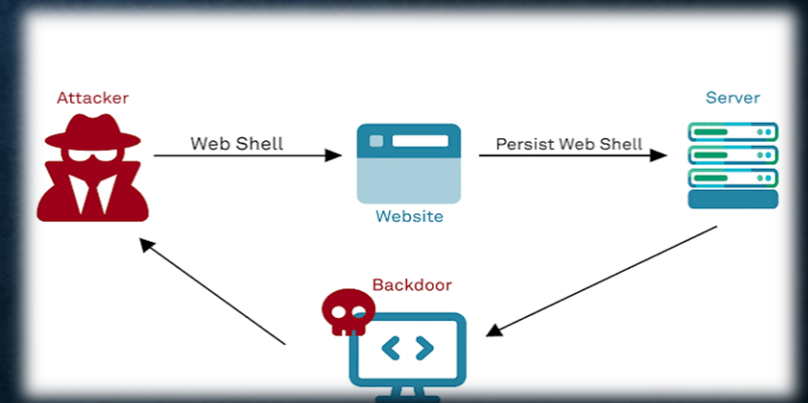
1. المقدمة
2. ما هي ثغرة رفع الملفات؟
3. أسباب حدوث ثغرة رفع الملفات
4. اضرار ثغرة رفع الملفات
5. أحداث هزت سيرفرات ضخمة
6. الملفات المخادعة
7. اخطر انواع الملفات
8. طرق الوقاية والحماية

# ما هي ثغرة رفع الملفات؟

تخيّل أنك أنشأت موقعًا إلكترونيًا مخصصًا للتواصل بين أصدقائك، وقررت أن تسمح برفع الصور بصيغتين فقط، وهما **JPG and PNG** معتقدًا أن ذلك كافٍ لحماية الموقع. لكن المهاجم يفكر بطريقة مختلفة فهو يحاول رفع ملف **evil.php** او اي نوع اخر يحتوي على سكربت خبيث بدلًا من صورة عادية. إذا نجح الموقع في قبول هذا الملف وتنفيذه على الخادم، فسيبدأ السكربت بالعمل فورًا، مما يمنح المهاجم القدرة على تنفيذ أوامر أو التحكم في الموقع. عند هذه النقطة تكون قد وقعت في **ثغرة رفع الملفات (File Upload Vulnerability)** ، وهي من الثغرات الخطيرة التي تنتج عن عدم التحقق الصحيح من نوع الملف ومحتواه قبل رفعه إلى الخادم.



## FILE UPLOAD VULNERABILITIES



# أسباب حدوث ثغرة رفع الملفات

- غياب الفحص :الاعتماد على امتداد الملف فقط دون التحقق من محتواه على الخادم.
- فحص غير كافٍ :استخدام قائمة لحظر (**Blacklisting**) بدلاً من السماح بالأنواع الموثوقة فقط. (**Whitelisting**)
- تخزين غير آمن :حفظ الملفات في مجلدات يمكن الوصول إليها مباشرة، مما قد يسمح بتنفيذ الملفات الخبيثة .
- صلاحيات خاطئة: منح الملفات أو المجلدات صلاحيات تنفيذ مرتفعة (Execution Permissions) مما يسمح بتشغيل

الملفات الخبيثة.



**FILE-UPLOAD**  
VULNERABILITY  
Basic to advanced



# أضرار ثغرة رفع الملفات

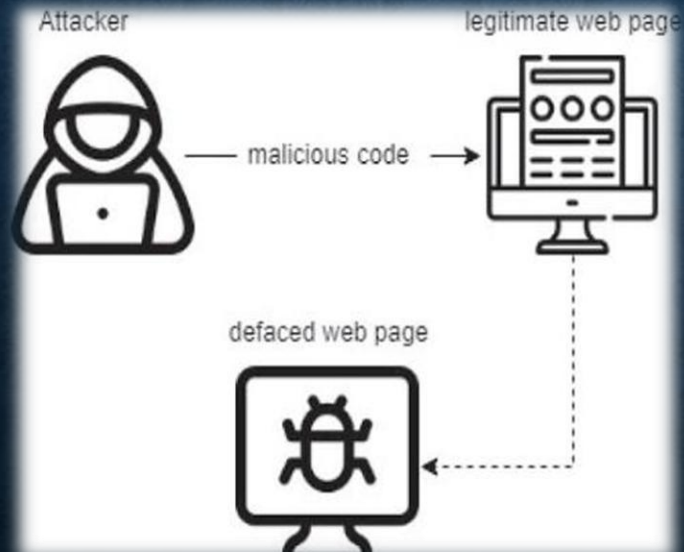
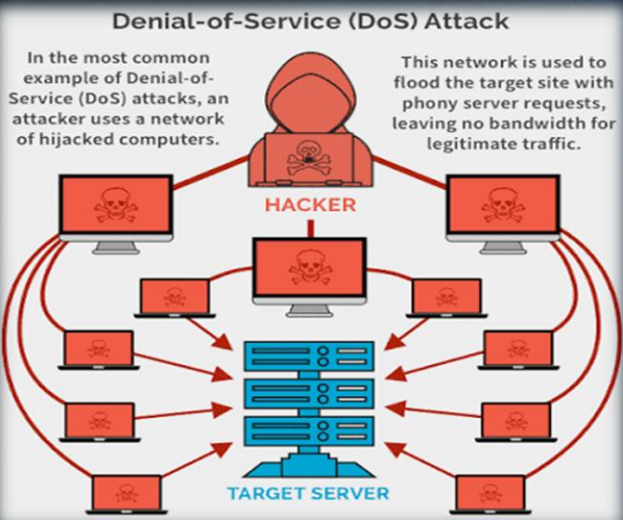
➤ التحكم في الخادم: (Remote Code Execution - RCE) رفع وتشغيل ملفات خبيثة مثل PHP أو ASP

مما يسمح للمهاجم بتنفيذ أوامر مباشرة على الخادم.

➤ سرقة وتسريب البيانات: (Data Breach) الوصول إلى قواعد البيانات وملفات العملاء وسرقة المعلومات الحساسة.

➤ هجمات حجب الخدمة: (Denial of Service - DoS) استهلاك موارد الخادم أو مساحة التخزين عبر رفع ملفات ضخمة أو بأعداد كبيرة.

➤ تشويه الموقع: (Website Defacement) تعديل صفحات الموقع أو استبدال محتواها ونشر برمجيات خبيثة للزوار .

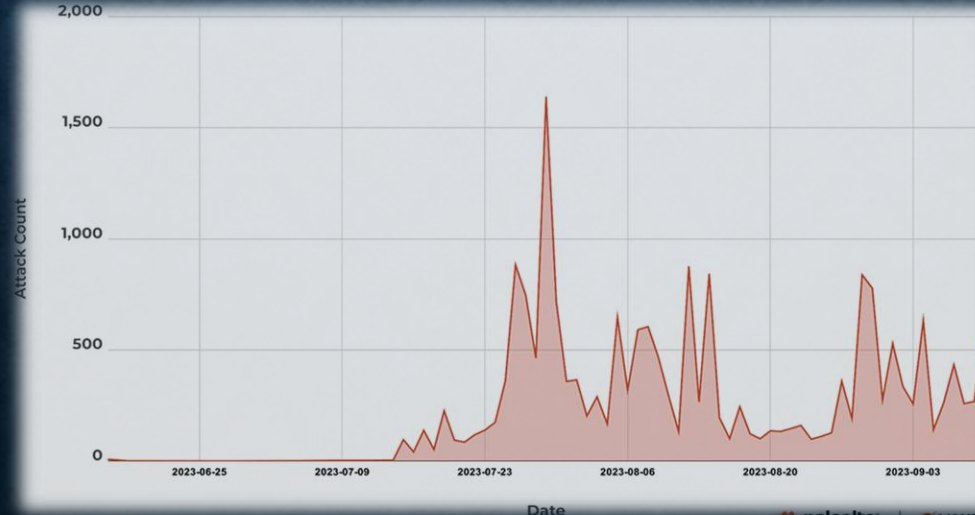


# أحداث هزت سيرفرات ضخمة !

## 1. اختراق برمجية MOVEit Transfer (عام 2023) – أحد أكبر الهجمات السيبرانية في التاريخ

استغلت عصابة الفدية الروسية الشهيرة "Clop" ثغرة حقن وقصور في رفع/نقل الملفات داخل النظام [alarabiya , aljazeera]

- حجم الضرر: تم اختراق بيانات أكثر من **2,600 شركة ومؤسسة حكومية كبرى** حول العالم.
- عدد الضحايا: تسريب بيانات الحسابات والمعلومات الحساسة لقرابة **90 مليون شخص**.
- أبرز الجهات المتضررة التابعة لها: وزارة الطاقة الأمريكية، كبرى شركات المحاسبة الأربعة (مثل EY و Deloitte)، والخطوط الجوية البريطانية، ونظام التقاعد الأكبر في **أمريكا**.
- الخسائر المالية: قُدرت التكلفة الإجمالية لعمليات معالجة وتطهير الأنظمة وتعويض الضحايا **بمليارات الدولارات [1, 2, 3]**.



# الملفات المخادعة



➤ ملفات SVG تحتوي على جافا سكريبت :تستخدم لتنفيذ هجمات XSS وسرقة بيانات الجلسات.

➤ ملفات HTML المزيفة :تُستغل لخداع المستخدمين أو سرقة كلمات المرور عبر متصفحاتهم.

➤ الملفات ذات الامتدادات المزدوجة مثل: **(file.php.jpg)** تُستغل لتجاوز فلاتر الحماية الضعيفة في المواقع .

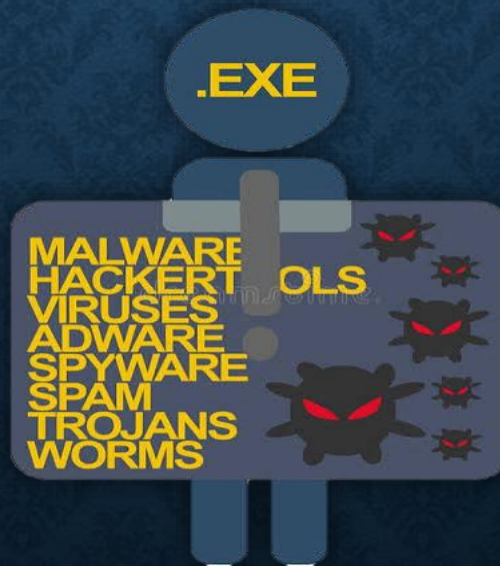
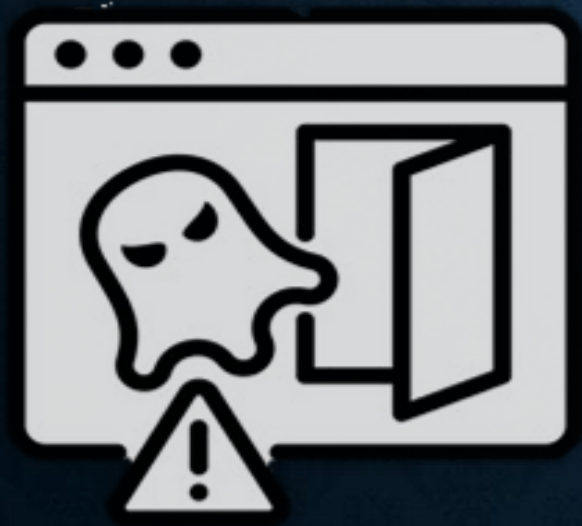
➤ ملفات ال PDF المدمجة ب Java Script : تُستغل لتنفيذ أكواد خبيثة تلقائياً بمجرد فتح الملف أو توجيه

المستخدم لروابط احتيالية لسرقة بياناته.



# أخطر أنواع الملفات

- **ملفات السكريبت: (PHP, ASP, JSP, Py)** تسمح بتنفيذ الأوامر البرمجية والوصول المباشر لقواعد البيانات وملفات النظام.
- **ملفات الـ Web Shell:** تُستخدم كواجهة تحكم بعيدة لإعطاء المخترق صلاحيات كاملة على خادم الويب.
- **ملفات التنفيذ المباشر: (EXE, Sh, Bat)** تستهدف الأنظمة الداخلية في حال تم تنزيلها وتشغيلها بالغلط من مسؤول النظام.



# طرق الوقاية والحماية

- ❑ التحقق من الملفات على الخادم (Server-Side Validation) وعدم الاعتماد على المتصفح فقط.
- ❑ استخدام القائمة البيضاء (Whitelisting) للسماح بأنواع ملفات محددة فقط.
- ❑ فحص محتوى الملف (Content Validation) للتأكد من أنه يطابق نوعه الحقيقي.
- ❑ إعادة تسمية الملفات (File Renaming) لمنع استغلال أسمائها الأصلية.
- ❑ تخزين الملفات خارج مجلدات التنفيذ (Non-Executable Directories) لمنع تشغيلها.
- ❑ تقييد صلاحيات الملفات (Least Privilege) بحيث لا تمتلك صلاحيات تنفيذ غير ضرورية.
- ❑ استخدام جدار حماية تطبيقات الويب (Web Application Firewall - WAF) لاكتشاف ومنع محاولات الاستغلال.
- ❑ استخدام آلية التحقق من الروبوتات (CAPTCHA) للحد من عمليات الرفع الآلية والهجمات المؤتمتة.

